

FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



INFORMES CIBERSEGURIDAD

Curso:

CIBERSEGURIDAD

Docente:

HERNAN OSWALDO VILLAFUERTE BARRETO

Autor

MAYTA LAURA ENZO IVAN

INFORME PRUEBA ENTIDAD

1. Objetivo

El objetivo de esta actividad fue realizar una fase de reconocimiento y auditoría básica sobre los dominios sanna.pe y laptopshop.pe para identificar métodos HTTP permitidos, redirecciones y posibles vulnerabilidades de configuración.

2. Herramientas Utilizadas (Entorno Kali Linux)

- **cURL:** Utilizado para la transferencia de datos y análisis detallado de cabeceras.
- **Nmap:** Empleado para el escaneo de servicios y descubrimiento de métodos HTTP.
- **Nikto:** Escáner de servidores web para detectar configuraciones inseguras y archivos peligrosos.
- **Nuclei:** Escáner basado en plantillas para la detección rápida de vulnerabilidades y configuraciones erróneas.

3. Procedimiento y Comandos Ejecutados

A. Análisis con cURL (Verbose Mode)

El uso de `-v` (verbose) permitió observar el *handshake* y el intercambio de cabeceras entre el cliente y el servidor.

- `curl -v www.sanna.pe`: Solicitud básica para verificar respuesta inicial.
- `curl -v https://www.sanna.pe`: Verificación mediante protocolo seguro (TLS/SSL).
- `curl -v -L www.sanna.pe`: Seguimiento de redirecciones (`-L`). Fundamental para ver si el sitio redirige de HTTP a HTTPS.
- `curl -v -X OPTIONS [url]`: Solicitud para listar los métodos HTTP permitidos (como GET, POST, HEAD, OPTIONS).

B. Análisis de Seguridad y Vulnerabilidades

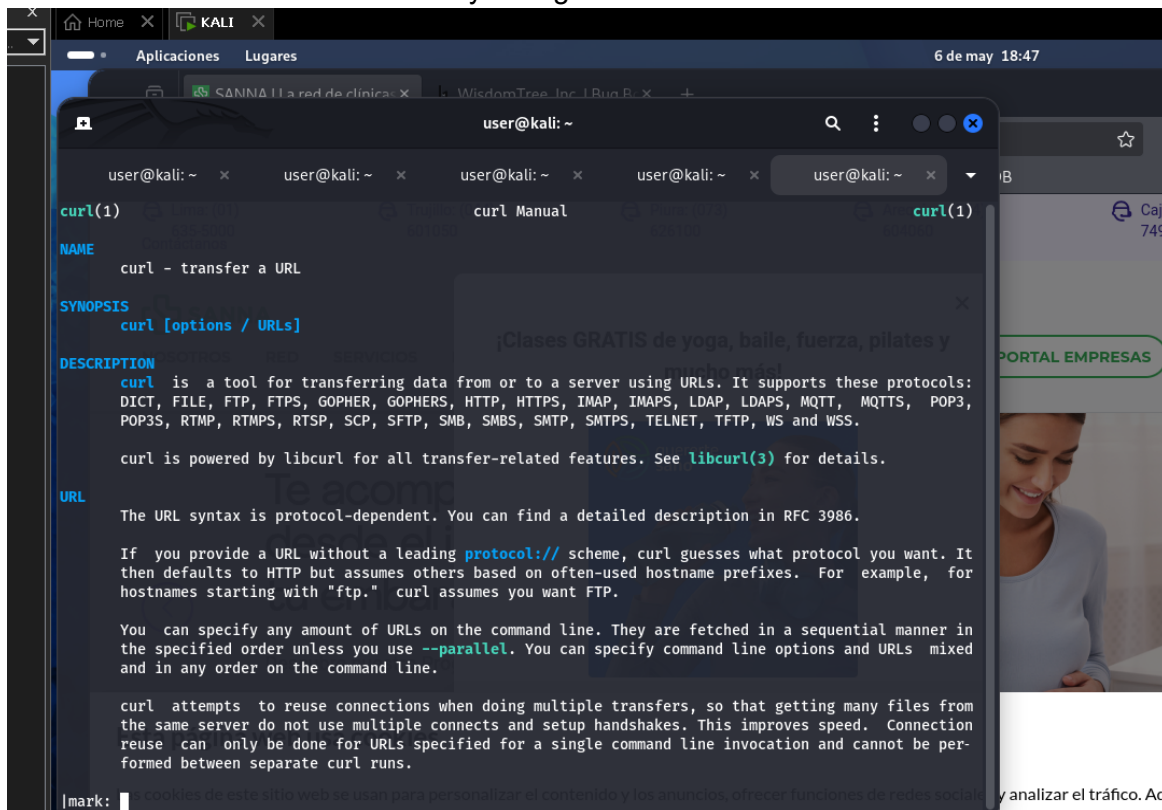
- **Nmap (HTTP Methods):** `nmap --script=http-methods.nse www.sanna.pe -p443` *Este comando identifica específicamente qué métodos HTTP permite el servidor, lo cual es crítico para evitar configuraciones como PUT o DELETE mal protegidas.*
- **Nikto:** `nikto -h https://www.sanna.pe/ nikto -h laptopshop.pe` *Nikto analizó los servidores buscando versiones obsoletas, cabeceras de seguridad ausentes y archivos expuestos.*
- **Nuclei:** *nuclei Herramienta utilizada para el escaneo automatizado basado en plantillas de vulnerabilidades conocidas (CVEs).*

4. Resumen de ejecución:

Herramienta	Función Principal	Entidad Analizada
cURL	Inspección de cabeceras y redirecciones	sanna.pe
Nmap	Detección de métodos HTTP permitidos	sanna.pe
Nikto	Escaneo de vulnerabilidades del servidor	sanna.pe, laptopshop.pe
Nuclei	Análisis automatizado de seguridad	wisdomtree.inc

5. Desarrollo

Dentro de la máquina virtual usando Kali Linux, se usa el terminal con el comando curl para abrir el manual y escoger los comandos a utilizar.



```
user@kali: ~  
curl(1)  
NAME  
curl - transfer a URL  
SYNOPSIS  
curl [options / URLs]  
DESCRIPTION  
curl is a tool for transferring data from or to a server using URLs. It supports these protocols:  
DICT, FILE, FTP, FTPS, GOPHER, GOPHERS, HTTP, HTTPS, IMAP, IMAPS, LDAP, LDAPS, MQTT, MQTTS, POP3,  
POP3S, RTMP, RTMPS, RTSP, SCP, SFTP, SMB, SMBS, SMTP, SMTPS, TELNET, TFTP, WS and WSS.  
curl is powered by libcurl for all transfer-related features. See libcurl\(3\) for details.  
URL  
The URL syntax is protocol-dependent. You can find a detailed description in RFC 3986.  
If you provide a URL without a leading protocol:// scheme, curl guesses what protocol you want. It  
then defaults to HTTP but assumes others based on often-used hostname prefixes. For example, for  
hostnames starting with "ftp." curl assumes you want FTP.  
You can specify any amount of URLs on the command line. They are fetched in a sequential manner in  
the specified order unless you use --parallel. You can specify command line options and URLs mixed  
and in any order on the command line.  
curl attempts to reuse connections when doing multiple transfers, so that getting many files from  
the same server do not use multiple connects and setup handshakes. This improves speed. Connection  
reuse can only be done for URLs specified for a single command line invocation and cannot be per-  
formed between separate curl runs.  
[mark: ] cookies de este sitio web se usan para personalizar el contenido y los anuncios, ofrecer funciones de redes sociales y analizar el tráfico. Ad
```

Fig. 1. Manual curl

La entidad a probar es sanna.pe, empresa de consultoría medica en peru.

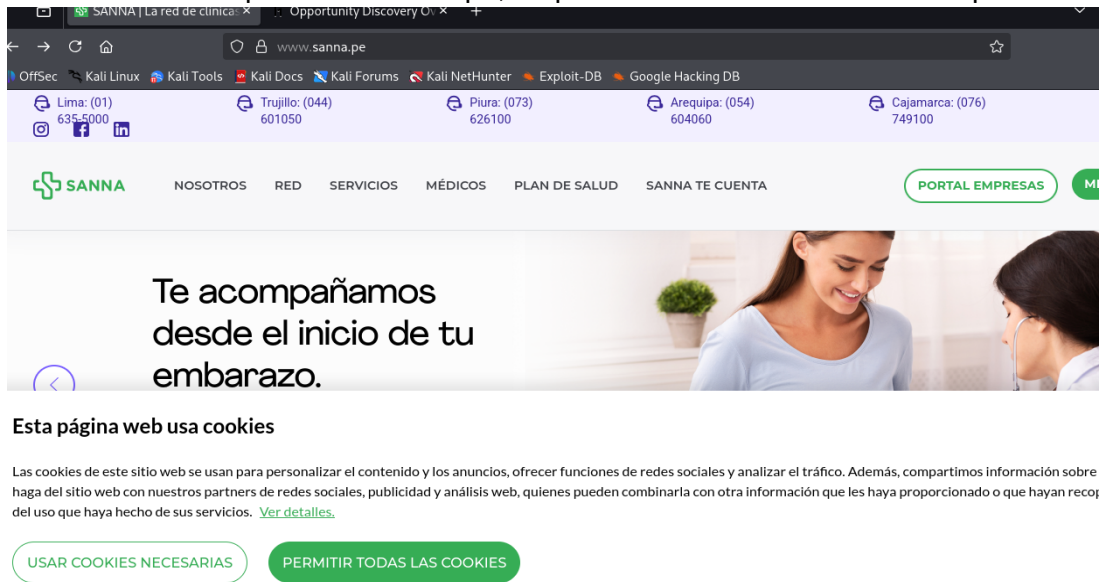


Fig. 2. Sanna.pe

Iniciamos con curl -v para hacer solicitud básica de respuesta, nos retorna las ip, nos muestra el puerto que utiliza que es 80.

```
L$ curl -v www.sanna.pe
* Host www.sanna.pe:80 was resolved.
* IPv6: 2600:1419:3200::be62:a159, 2600:1419:3200::be62:a162
* IPv4: 184.25.116.9, 184.25.116.18
* Trying [2600:1419:3200::be62:a159]:80...
* Immediate connect fail for 2600:1419:3200::be62:a159: La red es inaccesible
* Trying 184.25.116.9:80...
* Established connection to www.sanna.pe (184.25.116.9 port 80) from 192.168.152.128 port 411
* using HTTP/1.x
* GET / HTTP/1.1
* Host: www.sanna.pe
* User-Agent: curl/8.19.0
* Accept: */*
* Request completely sent off
* HTTP/1.1 301 Moved Permanently
* Content-Length: 0
* Location: https://www.sanna.pe/
* Expires: Wed, 06 May 2026 22:23:47 GMT
* Cache-Control: max-age=0, no-cache, no-store
* Pragma: no-cache
* Date: Wed, 06 May 2026 22:23:47 GMT
* Connection: keep-alive
* Server-Timing: cdn-cache; desc=HIT
* Server-Timing: edge; dur=1
* Server-Timing: ak_p; desc="1778106227299_3088675854_1413882145_12_11623_0_0_-";dur=1
* Connection #0 to host www.sanna.pe:80 left intact
```

Fig. 3. Solicitud de respuesta

Ahora se pone el mismo comando pero usando el protocolo https, la diferencia radica en que ahora nos presenta los certificados que ocupan a la par de mostrar un puerto distinto, siendo el

443

```
(user@kali)-[~]
$ curl -v https://www.sanna.pe
* Host www.sanna.pe:443 was resolved.
* IPv6: 2600:1419:3200::be62:a162, 2600:1419:3200::be62:a159
* IPv4: 184.25.116.18, 184.25.116.9
* Trying [2600:1419:3200::be62:a162]:443...
* Immediate connect fail for 2600:1419:3200::be62:a162: La red es inaccesible
* Trying 184.25.116.18:443...
* ALPN: curl offers h2,http/1.1
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
* SSL Trust Anchors:
*   CAfile: /etc/ssl/certs/ca-certificates.crt
*   Cpath: /etc/ssl/certs
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384 / x25519 / RSASSA-PSS
* ALPN: server accepted h2
* Server certificate:
*   subject: CN=www.sanna.pe
*   start date: Mar 24 14:58:36 2026 GMT
*   expire date: Jun 22 14:58:35 2026 GMT
*   issuer: C=US; O=Let's Encrypt; CN=R13
*   Certificate level 0: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
*   Certificate level 1: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
*   Certificate level 2: Public key type RSA (4096/152 Bits/secBits), signed using sha256WithRSAEncryption
*   subjectAltName: "www.sanna.pe" matches cert's "www.sanna.pe"
* OpenSSL verify result: 0
* SSL certificate verified via OpenSSL.
* Established connection to www.sanna.pe (184.25.116.18 port 443) from 192.168.152.128 port 51454
* using HTTP/2
* [HTTP/2] [1] OPENED stream for https://www.sanna.pe/
* [HTTP/2] [1] [:method: GET]
* [HTTP/2] [1] [:scheme: https]
* [HTTP/2] [1] [:authority: www.sanna.pe]
```

Fig. 4. Solicitud de respuesta con protocolo https

Ahora en las siguientes capturas se intenta listar los http permitidos para obtener respuestas mas especificas, pero el curl no es suficiente, nos rechaza indicando que el pedido fue expulsado.

```
(user@kali)-[~]
└─$ curl -v -L www.sanna.pe
* Host www.sanna.pe:80 was resolved.
* IPv6: 2600:1419:3200::be62:a159, 2600:1419:3200::be62:a162
* IPv4: 184.25.116.9, 184.25.116.18
* Trying [2600:1419:3200::be62:a159]:80...
* Immediate connect fail for 2600:1419:3200::be62:a159: La red es inaccesible
* Trying 184.25.116.9:80...
* Established connection to www.sanna.pe (184.25.116.9 port 80) from 192.168.152.128 port 39474
* using HTTP/1.x
> GET / HTTP/1.1
Host: www.sanna.pe
User-Agent: curl/8.19.0
Accept: /*/*

Request completely sent off
< HTTP/1.1 301 Moved Permanently
Content-Length: 0
Location: https://www.sanna.pe/
Expires: Wed, 06 May 2026 22:40:20 GMT
Cache-Control: max-age=0, no-cache, no-store
Pragma: no-cache
Date: Wed, 06 May 2026 22:40:20 GMT
Connection: keep-alive
Server-Timing: cdn-cache; desc=HIT
Server-Timing: edge; dur=1
Server-Timing: ak_p; desc="1778107220503_3088675845_1708486064_12_8087_2_0_-";dur=1
* Ignoring the response-body
* setting size while ignoring
```

Fig. 5. Prueba de listado de metodos

```
(user@kali)-[~]
└─$ curl -v -X OPTIONS www.sanna.pe
* Host www.sanna.pe:80 was resolved.
* IPv6: 2600:1419:3200::be62:a162, 2600:1419:3200::be62:a159
* IPv4: 184.25.116.9, 184.25.116.18
* Trying [2600:1419:3200::be62:a162]:80...
* Immediate connect fail for 2600:1419:3200::be62:a162: La red es inaccesible
* Trying 184.25.116.9:80...
* Established connection to www.sanna.pe (184.25.116.9 port 80) from 192.168.152.128 port 57440
* using HTTP/1.x
> OPTIONS / HTTP/1.1
Host: www.sanna.pe
User-Agent: curl/8.19.0
Accept: /*/*

Request completely sent off
< HTTP/1.1 301 Moved Permanently
Content-Length: 0
Location: https://www.sanna.pe/
Expires: Wed, 06 May 2026 22:47:12 GMT
Cache-Control: max-age=0, no-cache, no-store
Pragma: no-cache
Date: Wed, 06 May 2026 22:47:12 GMT
Connection: keep-alive
Server-Timing: ak_p; desc="1778107632101_3088675854_1432035513_12_26748_0_0_-";dur=1
* Connection #0 to host www.sanna.pe:80 left intact
```

Fig. 6. Prueba de listado de metodos

Por ellos se hace uso del nmap con este comando para identificar específicamente qué métodos http permite el servidor, y se ve que si nos retorna

```
(user@kali)-[~]
└─$ nmap --script=http-methods.nse www.sanna.pe -p443
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 17:54 -0500
Nmap scan report for www.sanna.pe (184.25.116.9)
Host is up (0.0013s latency).
Other addresses for www.sanna.pe (not scanned): 184.25.116.18 2600:1419:3200::be62:a162 2600:1419:3200::be62:a159
rDNS record for 184.25.116.9: a184-25-116-9.deploy.static.akamaitechnologies.com

PORT      STATE SERVICE
443/tcp   open  https
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
Nmap done: 1 IP address (1 host up) scanned in 0.62 seconds
```

Fig. 7. Prueba de listado de métodos con nmap

Pero aun así la conexión es rechazada indicándonos que es inaccesible, lo positivo es que no muestra el método trace, que este lo que hace es interceptar los mensajes entre el cliente y servidor.

```
(user@kali)-[~]
└─$ curl -v -X OPTIONS https://www.sanna.pe
* Host www.sanna.pe:443 was resolved.
* IPv6: 2600:1419:3200::be62:a162, 2600:1419:3200::be62:a159
* IPv4: 184.25.116.9, 184.25.116.18
* Trying [2600:1419:3200::be62:a162]:443...
* Immediate connect fail for 2600:1419:3200::be62:a162: La red es inaccesible
* Trying 184.25.116.9:443...
* ALPN: curl offers h2,http/1.1
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
* SSL Trust Anchors:
*   CAfile: /etc/ssl/certs/ca-certificates.crt
*   CAPath: /etc/ssl/certs
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384 / x25519 / RSASSA-PSS
* ALPN: server accepted h2
* Server certificate:
*   subject: CN=www.sanna.pe
*   start date: Mar 24 14:58:36 2026 GMT
*   expire date: Jun 22 14:58:35 2026 GMT
*   issuer: C=US; O=Let's Encrypt; CN=R13
*   Certificate level 0: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
*   Certificate level 1: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
*   Certificate level 2: Public key type RSA (4096/152 Bits/secBits), signed using sha256WithRSAEncryption
*   subjectAltName: "www.sanna.pe" matches cert's "www.sanna.pe"
* OpenSSL verify result: 0
* SSL certificate verified via OpenSSL.
* Established connection to www.sanna.pe (184.25.116.9 port 443) from 192.168.152.128 port 35480
* using HTTP/2
* [HTTP/2] [1] OPENED stream for https://www.sanna.pe/
* [HTTP/2] [1] [:method: OPTIONS]
* [HTTP/2] [1] [:scheme: https]
```

Fig. 8. Prueba de listado de métodos

Si nos retornase que este método trace es usable habría problemas de seguridad.

```
PORT      STATE SERVICE
80/tcp    open  http
| http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
```

Fig. 9. Listado de metodos

```
nmap@kali:[-]  
nikto -h https://www.sanna.pe/  
vkt0 v2.6.0  
  
Target IP:      184.25.116.9  
Target Hostname: www.sanna.pe  
Target Port:    443  
  
I Info:  
Subject: /CN=www.sanna.pe  
CN:       www.sanna.pe  
SAN:      admin.qa.querertesanodev.com, admin.qa.sannadev.com, admin.querertesano.pe, admin.querertesanodev.com, admin.sanna.pe, admin.sannadev.com, admin.tsana.pe, admin.tsananosprd.com, age  
liento.qa.sannadev.com, agendamiento.sanna.pe, agendamientosnnodev.com, api.qa.querertesanodev.com, api.qa.sannadev.com, api.querertesano.pe, api.querertesanodev.com, apisannape.  
api.tsananosprd.com, apiasegurabilidad.doctormas.com.pe, apitopicare.doctormas.com.pe, app.sanna.pe, argocd.querertesano.pe, argocd.querertesanodev.com, argocd.sanna.pe, argocd.sannadev.com, argocd.tsana.pe,  
argocd.tsananosprd.com, asegurabilidad.doctormas.com.pe, chequeos.sanna.pe, clinicablen.vpn.sanna.pe, core.qa.sannadev.com, core.sanna.pe, coresannadev.com, dash.qa.sannadev.com, dash.sannadev.com, doctoradomic  
.doctormas.com, doctordonline.doctormas.com.pe, medicosdentrosclinicados.doctormas.com.pe, medweb.doctormas.com.pe, mfa.prestadoras.com, mfa.prestadorasanoprd.com, mfaadm.presta  
das.com, mfasidm.prestadorasanoprd.com, promedica.doctormas.com.pe, qa.querertesanodev.com, rxaso.doctormas.com.pe, seguimientodoctormas.com.pe, topicare-doctormas.com.pe, tsananoprd.com, www.midoc.pe, www.qa.q  
uerertesanodev.com, www.qa.sannadev.com, www.querertesano.pe, www.querertesanodev.com, www.sanna.pe, www.sannadev.com, www.tsana.pe, www.tsananosprd.com  
  
Ciphers: TLS_AES_256_GCM_SHA384  
Issuer:   /C=US/O=Lets Encrypt/CN=R13  
Platform: Unknown  
Start Time: 2026-05-06 18:20:03 (GMT-5)  
  
-----  
Server: No banner retrieved  
Banner: Failed to find: 184.25.116.9, 184.25.116.18, 2600:1419:3200::be62:a159, 2600:1419:3200::be62:a162  
ERROR: Unable to check for updates: 429  
[1779] / : An alt-svc header was found which is advertising HTTP/3. The endpoint is: ':443'. Nikto cannot test HTTP/3 over QUIC. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/alt-svc  
CGI Directories found (use '-c all' to force check all possible dirs). CGI tests skipped.  
[[{"ip": "013587"] / : Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy  
[13587] / : Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP  
[13587] / : Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
[13587] / : Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
[13587] / : Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
```

Aca un cuadro explicativo de los hallazgos obtenidos por nikto.

Hallazgo	Descripción de la vulnerabilidad	Impacto potencial	Tipos de ataques posibles	Nivel de riesgo
Exposición de múltiples subdominios en el certificado SSL	El certificado TLS revela dominios internos, administrativos, QA y APIs.	Permite a un atacante conocer parte de la infraestructura y localizar servicios sensibles.	Reconocimiento de infraestructura, enumeración de servicios, ataques a entornos QA/DEV, ataques a APIs.	Medio
Falta de Content-Security-Policy (CSP)	No existe una política que restrinja qué scripts y recursos pueden ejecutarse en el navegador.	Mayor probabilidad de ejecución de scripts maliciosos y robo de sesiones.	Cross-Site Scripting (XSS), inyección de scripts externos, secuestro de sesión.	Alto
Falta de Strict-Transport-Security (HSTS)	El navegador no es obligado a usar HTTPS permanentemente.	Posibilidad de degradar conexiones seguras hacia HTTP inseguro.	SSL Stripping, Man-in-the-Middle (MITM), interceptación de tráfico.	Alto
Falta de X-Content-Type-Options	El navegador puede interpretar incorrectamente tipos de archivos (MIME sniffing).	Ejecución inesperada de contenido malicioso.	MIME Sniffing, ejecución de scripts maliciosos.	Medio
Falta de Referrer-Policy	No se controla la información enviada en los encabezados Referer.	Exposición accidental de URLs con información sensible.	Filtración de información, seguimiento de usuarios.	Medio
Falta de Permissions-Policy	No se restringe el acceso a funcionalidades sensibles del navegador.	Scripts maliciosos podrían intentar acceder a recursos del dispositivo.	Abuso de APIs del navegador, ataques de privacidad.	Bajo
HTTP/3 detectado pero no analizado	Nikto detectó soporte HTTP/3 pero no puede auditarlo.	Parte de la superficie de ataque podría quedar sin revisar.	Posibles vulnerabilidades no detectadas en QUIC/HTTP3.	Bajo

Fig. 11. Resultados nikto

Ahora haciendo uso del software NIKTO en la empresa LAPTOPSHOP

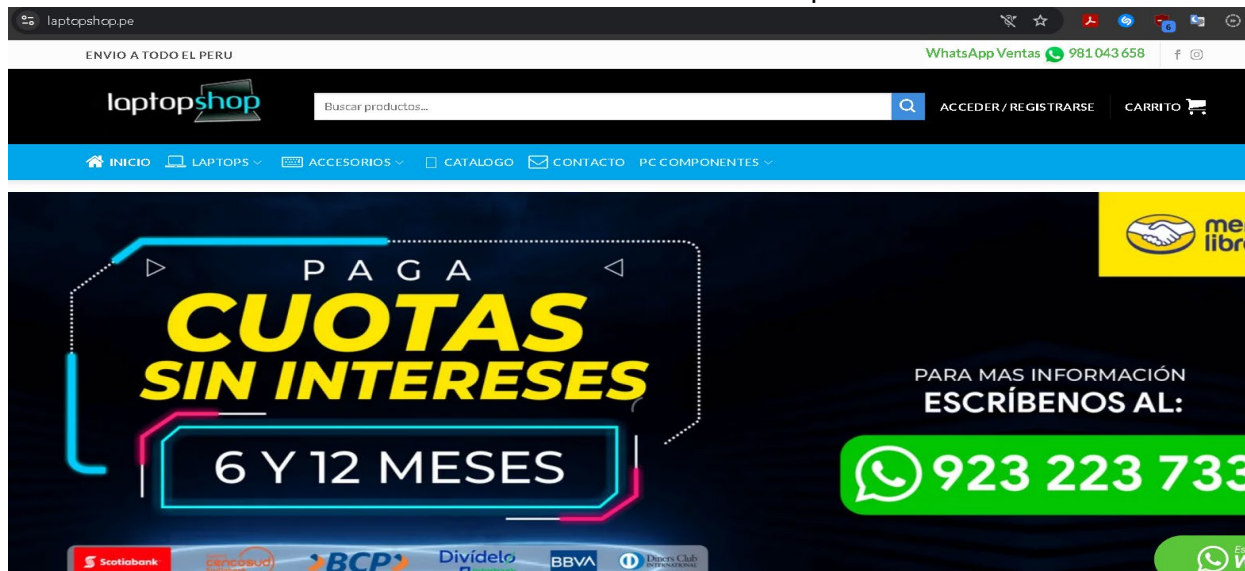


Fig. 12. Laptopshop

De igual manera nos retorna la ip y el puerto que utilizan.

```
(user@kali:~)
$ nikto -h laptopshop.pe
- Nikto v2.6.0

-----
* Target IP: 88.222.222.17
* Target Hostname: laptopshop.pe
* Target Port: 80
* Platform: Unknown
* Start Time: 2026-05-06 18:19:04 (GMT-5)
-----

* Server: hcdn
* Multiple IPs found: 88.222.222.17, 84.32.84.195, 2a02:4780:84:ce3e:eeb8:945f:e8bc:b654, 2a02:4780:84:f63c:5328:21b9:ce4a:d883
* ERROR: Failed to check for updates: 429
* [999100] /: Uncommon header(s) 'platform' found, with contents: hostinger.
* [999100] /: Uncommon header(s) 'panel' found, with contents: hpanel.
* [999100] /: Uncommon header(s) 'x-hcdn-request-id' found, with contents: e99df774c8f757deb1cca15d3789e110-san-edge2.
* [999100] /: Uncommon header(s) 'x-hcdn-cache-status' found, with contents: HIT.
* [011799] /: An alt-svc header was found which is advertising HTTP/3. The endpoint is: ':443'. Nikto cannot test HTTP/3 over QUIC. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/alt-svc
* [999100] /server-status: Uncommon header(s) 'x-hcdn-upstream-rt' found, with contents: 0.100.
* No CGI Directories found (use '-C all' to force check all possible dirs), CGI tests skipped.
* ERROR: *** Error limit (20) reached for host, giving up. Last error: error reading HTTP response. ***
* ERROR: *** Consider using mitmproxy to avoid TLS fingerprinting. ***
* STATUS: Completed 114 requests (~2% complete, ~10.4 minutes left): currently in plugin 'Site Files'
* STATUS: Running average: Not enough data.
* Scan terminated: 20 errors and 6 items reported on the remote host
* End Time: 2026-05-06 18:19:14 (GMT-5) (10 seconds)
-----
* 1 host(s) tested
```

Fig. 13. Resultados nikto laptopshop

A diferencia de Sanna.pe, laptop shop usando nikto muestra riesgos menores.

Hallazgo	Descripción de la vulnerabilidad	Impacto potencial	Tipos de ataques posibles	Nivel de riesgo
Divulgación de tecnología (platform: hostinger)	El servidor revela el proveedor de hosting utilizado.	Facilita la identificación de la infraestructura y tecnologías empleadas.	Fingerprinting, reconocimiento de infraestructura, ataques dirigidos a Hostinger.	Medio
Divulgación de panel administrativo (panel: hpanel)	El encabezado expone el uso del panel administrativo HPANEL.	Permite a atacantes identificar posibles vectores de acceso administrativo.	Fuerza bruta, credential stuffing, reconocimiento de paneles administrativos.	Medio
Exposición de encabezados internos CDN (x-hcdn-*)	Se muestran encabezados internos relacionados con Hostinger CDN.	Filtración de información sobre caché, nodos edge y arquitectura interna.	Reconocimiento de red, análisis de infraestructura CDN, evasión de caché.	Bajo

Fig. 14. Resumen de resultados nikto

Para el test de nuclei se hizo la prueba en la empresa wisdomtree, pero al ser una empresa mas robusta en seguridad el análisis de nuclei demoro más, agregando el hecho de ser una maquina virtual con recursos ajustados. Aun así nos retorno con enlaces e informaciones de api o dominios utilizando donde hay problemas de seguridad.



Fig. 12. wisdomtree

```
user@kali: ~
user@kali: ~
user@kali: ~
user@kali: ~

nuclei v3.8.0
projectdiscovery.io

[INF] nuclei-templates are not installed, installing...
[INF] Successfully installed nuclei-templates at /home/user/.local/nuclei-templates
[WRN] Found 1 templates with runtime error (use -validate flag for further examination)
[INF] Current nuclei version: v3.8.0 (latest)
[INF] Current nuclei-templates version: v10.4.3 (latest)
[INF] New templates added in latest release: 103
[INF] Templates loaded for current scan: 10194
[INF] Executing 10178 signed templates from projectdiscovery/nuclei-templates
[WRN] Loading 16 unsigned templates for scan. Use with caution.
[INF] Targets loaded for current scan: 1
[INF] Running httpx on input host
[INF] Found 1 URL from httpx
[INF] Templates clustered: 2292 (Reduced 2162 Requests)
[INF] Using Interactsh Server: oast.me
[waf-detect:cloudflare] [http] [info] https://api.wisdomtreeprimeapp.com
[tls-version] [ssl] [info] api.wisdomtreeprimeapp.com:443 ["tls12"]
[tls-version] [ssl] [info] api.wisdomtreeprimeapp.com:443 ["tls13"]
[tech-detect:cloudflare] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:content-security-policy] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:clear-site-data] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:permissions-policy] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:x-frame-options] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:referrer-policy] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] https://api.wisdomtreeprimeapp.com
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] https://api.wisdomtreeprimeapp.com
[weak-hsts-detect:hsts-header] [http] [info] https://api.wisdomtreeprimeapp.com ["max-age=15552000; includeSubDomains; preload"]
[aaaa-fingerprint] [dns] [info] api.wisdomtreeprimeapp.com ["2606:4700:3108::ac42:2b79","2606:4700:3108::ac42:2887"]
[caa-fingerprint] [dns] [info] api.wisdomtreeprimeapp.com
[ssl-issuer] [ssl] [info] api.wisdomtreeprimeapp.com:443 ["Google Trust Services"]
[ssl-dns-names] [ssl] [info] api.wisdomtreeprimeapp.com:443 ["wisdomtreeprimeapp.com","*.wisdomtreeprimeapp.com"]
[wildcard-tls] [ssl] [info] api.wisdomtreeprimeapp.com:443 ["CN: wisdomtreeprimeapp.com","SAN: [wisdomtreeprimeapp.com *.wisdomtreeprimeapp.com]"]
[INF] Scan completed in 6m. 19 matches found.
```

Fig. 13. Resultados nuclei